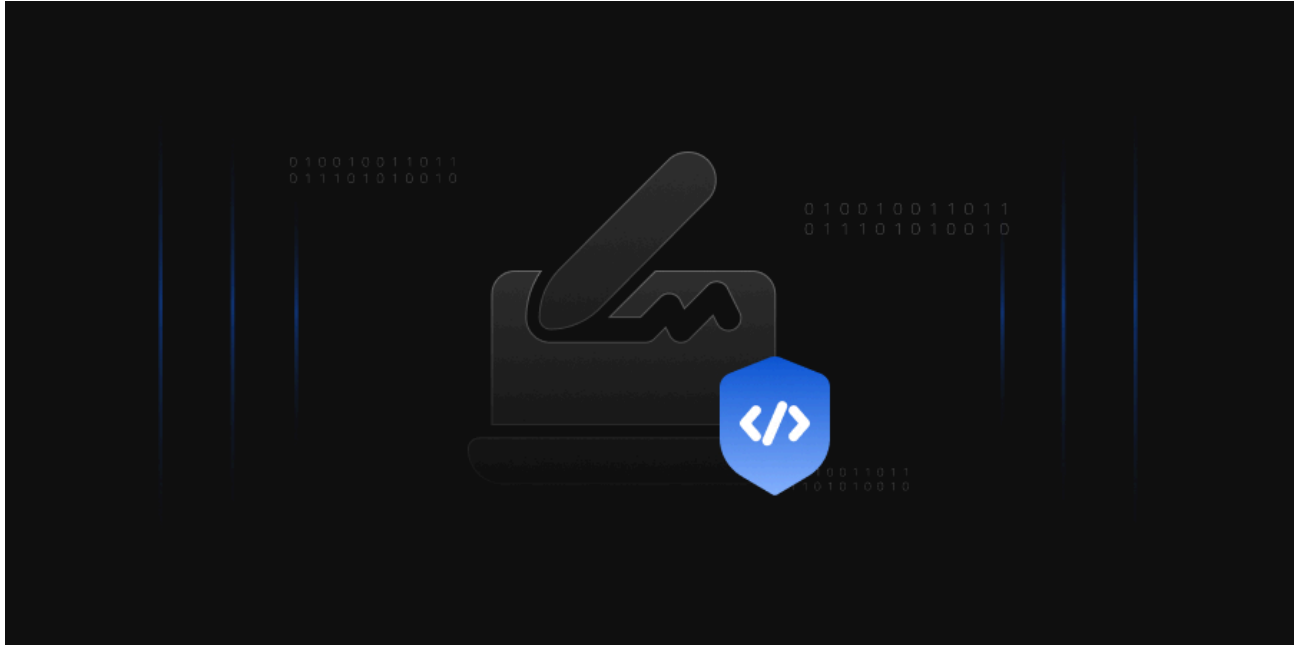


AD CS Template Hardening: ESC1–ESC16 Defense Playbook

 encryptionconsulting.com/ad-cs-template-hardening

Manimit Haldar

April 14, 2026



Microsoft [Active Directory Certificate Services \(AD CS\)](#) has served as the backbone of enterprise PKI for over two decades. It enables organizations to issue [digital certificates](#) for user authentication, computer identity, [code signing](#), encryption, smart card logon, and secure communications—all tightly integrated with Active Directory.

But that deep integration is a double-edged sword. [Certificate templates](#)—the policy objects that govern what certificates get issued, to whom, and with what privileges—are stored as AD objects themselves. A single misconfigured template can hand an attacker a path from unprivileged domain user to Enterprise Admin in minutes, without triggering traditional endpoint detection.

The SpecterOps [Certified Pre-Owned](#) whitepaper (2021) was the watershed moment, documenting eight escalation paths (ESC1–ESC8) that turned certificate template misconfigurations into domain compromise vectors. Since then, the taxonomy has expanded to **ESC16**, while Microsoft, CISA ([AA23-278A](#)), NSA, and Five Eyes partner agencies ([September 2024 Joint Advisory](#)) have responded with enforcement deadlines, patching mandates, and formal Tier 0 classification of CA infrastructure. This playbook delivers the technical depth that PKI administrators, security architects, and governance teams need. For foundational concepts, see Encryption Consulting’s guides on [What is PKI?](#), [Certificate Authorities](#), and [X.509 Certificates](#).

Certificate Template Anatomy: The Eight Significant Properties That Define Your Risk Posture

Every AD CS template is a pKICertificateTemplate object stored under CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration in Active Directory. The X.509 certificate profile is defined by [RFC 5280](#), while the certificate policy and certification practices statement framework follows [RFC 3647](#). Microsoft ships three schema versions:

- **Version 1** – Legacy templates. Limited editability, no autoenrollment. **Most dangerous** because Schema V1 templates are vulnerable to ESC15 ([CVE-2024-49019](#), EKU override via CSR).
- **Version 2** – Full configuration, autoenrollment, and all standard security controls.
- **Version 3** – Adds Suite B / CNG cryptographic algorithm support (ECDSA P-256/P-384/P-521), aligned with [NIST SP 800-57](#) key management recommendations.

Encon Internal SSL30days Properties



Subject Name		Issuance Requirements		
Superseded Templates		Extensions	Security	Server
General	Compatibility	Request Handling	Cryptography	Key Attestation
Template display name: Encon Internal SSL30days				
Template name: EnconInternalSSL30days				
Validity period: 1 months		Renewal period: 15 days		
☐ Publish certificate in Active Directory				
☐ Do not automatically reenroll if a duplicate certificate exists in Active Directory				
OK		Cancel	Apply	Help

Template Property Tabs and Their Security Implications

Property Tab	What It Controls	Most Common Security Mistake
General	Display name, template name (CN), validity period, renewal window, AD publication	Overly long validity periods (1–2 year defaults); publishing certificates to userCertificate attribute unnecessarily
Compatibility	Minimum CA and recipient OS versions, gating available cryptographic features	Leaving legacy OS compatibility enabled, preventing use of stronger algorithms
Request Handling	Purpose (Signature / Encryption / Both), private key exportability, CSP/KSP, minimum key size	Exportable private keys on high-value templates; allowing weak CSPs
Subject Name	Build from AD attributes vs. enrollee-supplied values (CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT)	Leaving enrollee-supplied SAN enabled — root cause of ESC1
Extensions	Extended Key Usages (EKUs) per RFC 5280 #4.2.1.12	AnyPurpose EKU, missing EKU (acts as SubCA), or overly broad authentication EKUs
Cryptography	Algorithm (RSA/ECDSA), key size, hash per NIST SP 800-57	SHA-1 still present; 1024-bit RSA keys still accepted

Property Tab	What It Controls	Most Common Security Mistake
Issuance Requirement	Manager approval, authorized enrollment agent signatures	No approval on sensitive templates (WebServer, CodeSigning, EnrollmentAgent)
Security / ACLs	Who can Read, Write, Enroll, Autoenroll, Full Control the template object	Authenticated Users or Domain Users granted Enroll on sensitive templates

Understanding Subject Types and Key Usage Categories

Every default template belongs to a subject type and key usage category. For deeper context on certificate structures, see [What is an X.509 Certificate?](#) and [RFC 5280 \(Internet X.509 PKI Certificate Profile\)](#).

Subject Types

- **User** – Certificates for human identities: authentication, email signing/encryption, EFS, code signing, smart card logon. Includes Administrator, User, SmartcardUser, EnrollmentAgent, CodeSigning, EFS Recovery Agent, Exchange User/Signature.
- **Computer** – Certificates for machine identities: server/client authentication, IPsec, Kerberos ([RFC 4556 – PKINIT](#)). Includes Computer, WebServer, DomainController, KerberosAuthentication, WorkstationAuthentication, RAS and IAS Server.
- **Certificate Authority (CA)** – Certificates that identify CAs within the [PKI hierarchy](#): Root CA, Subordinate CA, Cross-Certification Authority.
- **DirEmailRep** – Directory Email Replication for securing AD replication traffic.
- **Key Recovery Agent** – Certificates enabling authorized recovery of archived private keys, essential for [key management](#) governance.

Key Usage Categories

- **Signature Only** – Digital signatures for integrity and authenticity per [RFC 5280 #4.2.1.3](#) (CodeSigning, TrustListSigning, EnrollmentAgent, OCSP Response Signing, CA templates).
- **Encryption Only** – Key encipherment for confidentiality (BasicEFS, CEPEncryption, EFSRecovery, ExchangeUser, KeyRecoveryAgent).
- **Signature + Encryption** – Both operations (Administrator, Computer, User, DomainController, WebServer, SmartcardLogon, KerberosAuthentication, IPSec).

Best practice: Never modify default templates directly. Duplicate, disable the original, and harden the copy. See [Microsoft's AD CS hardening guide](#).

Default Templates: Risk Profiles You Must Know

Template	Default Enrollment	Dangerous Properties	Attack Vectors	Risk
User (V1)	Domain Users	Client Auth EKU, V1 schema	ESC3, ESC15	HIGH
Computer (V1)	Domain Computers	Client Auth EKU, V1 schema	ESC3, ESC8	HIGH
Web Server (V1)	Domain Admins (often broadened)	ENROLLEE_SUPPLIES_SUBJECT	ESC1, ESC15	CRITICAL
SubCA (V1)	Domain Admins	No EKU (SubCA behavior)	ESC7	CRITICAL
Enrollment Agent	Often broadened	Cert Request Agent EKU	ESC3 chain	HIGH

Most Common Enterprise Use Cases

Before diving into attack paths, let us understand the legitimate enterprise use cases. For a broader overview, see [Encryption Consulting's PKI Services](#):

- **Web Server / TLS:** The WebServer template issues certificates for internal HTTPS endpoints, governed by [RFC 8446 \(TLS 1.3\)](#) and [RFC 6125 \(certificate identity verification\)](#). It legitimately requires enrollee-supplied SANs, making it the #1 ESC1/ESC15 target when enrollment permissions are broadened. Publicly-trusted web certificates must also comply with [CA/Browser Forum Baseline Requirements](#).

ENCON SSL-TLS 30 Days 2026 Properties ? X

General	Compatibility	Request Handling	Cryptography	Key Attestation
Superseded Templates		Extensions	Security	Server

Subject Name

Issuance Requirements

☒ **Supply in the request**

☐ Use subject information from existing certificates for autoenrollment renewal requests

☐ **Build from this Active Directory information**

Select this option to enforce consistency among subject names and to simplify certificate administration.

Subject name format:

None

☐ Include e-mail name in subject name

Include this information in alternate subject name:

☐ E-mail name

☐ DNS name

☐ User principal name (UPN)

☐ Service principal name (SPN)

OK Cancel Apply Help

- **User Authentication (802.1X / VPN):** The User template provides EAP-TLS certificates for wireless authentication and VPN. Its broad enrollment to Domain Users makes it an ESC3/ESC15 vector.

- **Kerberos Authentication:** Domain Controllers use this template for [PKINIT-based Kerberos authentication \(RFC 4556\)](#), LDAPS, and DC-to-DC replication. Compromise enables domain persistence.

Kerberos Authentication Properties ? X

Subject Name		Issuance Requirements		
General	Compatibility	Request Handling	Cryptography	Key Attestation
Superseded Templates		Extensions	Security	Server

To modify an extension, select it, and then click Edit.

Extensions included in this template:

 Application Policies

 Basic Constraints

 Certificate Template Information

 Issuance Policies

 Key Usage

Edit...

Description of Application Policies:

Client Authentication
Server Authentication
Smart Card Logon
KDC Authentication

OK Cancel Apply Help

- **Code Signing:** Developers sign internal scripts and applications. See What is [Code Signing?](#) Private keys should **never** be exportable, and issuance should require manager approval.

ENCON Code Signing 2026 Properties ? X

Subject Name		Issuance Requirements		
General	Compatibility	Request Handling	Cryptography	Key Attestation
Superseded Templates		Extensions		Security
		Server		

To modify an extension, select it, and then click Edit.

Extensions included in this template:

 Application Policies

 Basic Constraints

 Certificate Template Information

 Issuance Policies

 Key Usage

Edit...

Description of Application Policies:

Code Signing

OK Cancel Apply Help

General	Compatibility	Request Handling	Cryptography	Key Attestation
Superseded Templates		Extensions	Security	Server
Subject Name		Issuance Requirements		

Require the following for enrollment:

☒ CA certificate manager approval

☒ This number of authorized signatures:

If you require more than one signature, autoenrollment is not allowed.

Policy type required in signature:

Application policy

Application policy:

Code Signing

Issuance policies:

Add...
Remove

Require the following for reenrollment:

☒ Same criteria as for enrollment

☐ Valid existing certificate

☐ Allow key based renewal (*)

Requires subject information to be provided within the certificate request.

* Control is disabled due to [compatibility settings](#).

OK Cancel Apply Help

- **Encryption (EFS / S/MIME):** BasicEFS and Exchange User templates protect file and email encryption. Key archival should be enabled for business continuity per [NIST SP 800-57 key management](#) guidance.

Enterprise PKI Services

Get complete end-to-end consultation support for all your PKI requirements!

[Learn More](#)

ESC1 Through ESC16: The Complete Attack Taxonomy

Attack paths fall into five categories. The full research is documented in the [Certified Pre-Owned whitepaper \(PDF\)](#), with ongoing updates via [BloodHound AD CS attack paths](#) and [MITRE ATT&CK T1649](#):

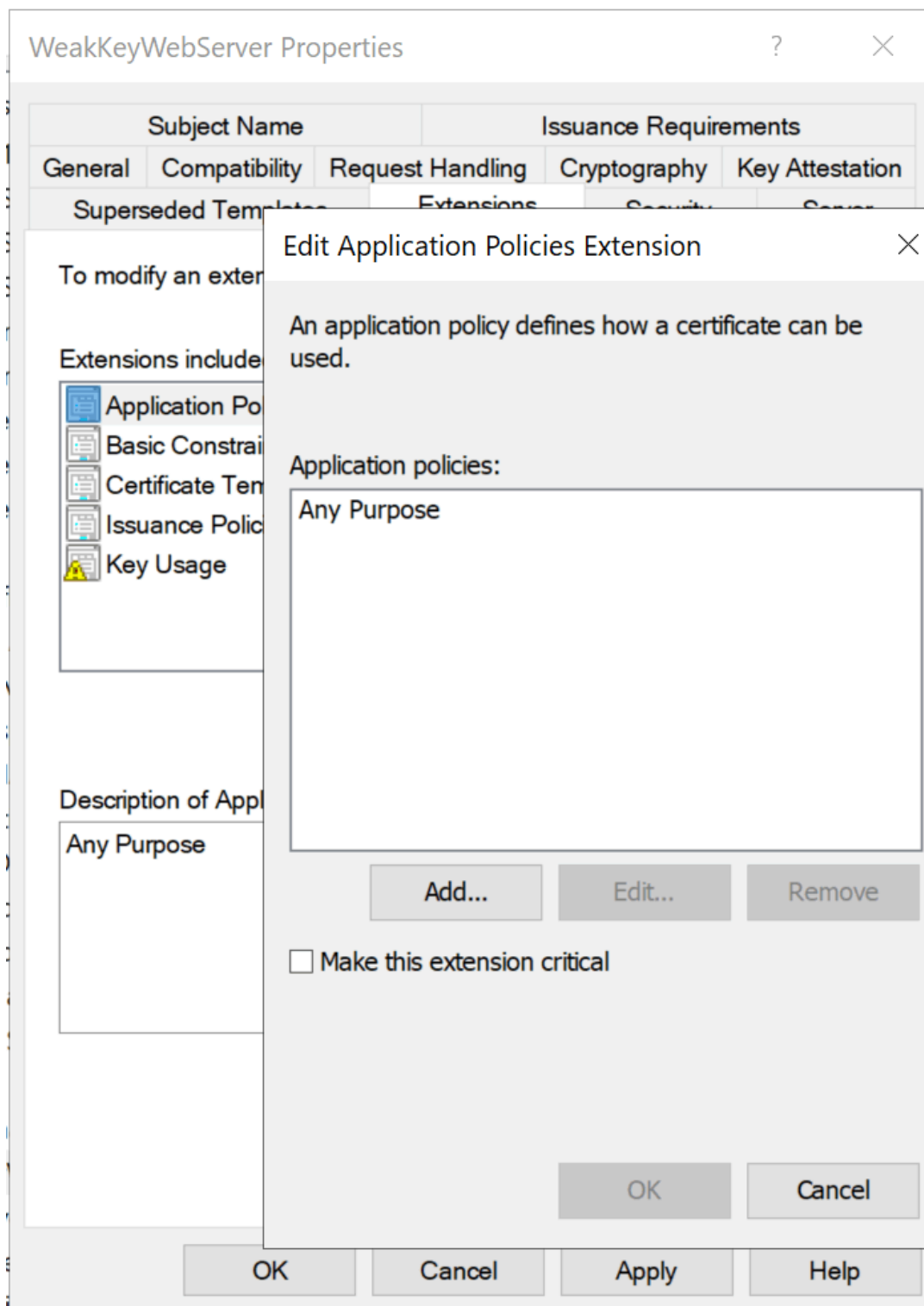
Template Misconfiguration Attacks

ESC1 — Enrollee-Supplied SAN (The #1 Path)

ESC1 requires: **(1)** CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT enabled, **(2)** Client Authentication ECU, **(3)** low-privileged enrollment, **(4)** no manager approval. The attacker specifies administrator@domain.local in the SAN and authenticates via [RFC 4556](#). Total time to Enterprise Admin: under 60 seconds.

ESC2 — AnyPurpose or Missing ECU

Templates with **AnyPurpose ECU (OID 2.5.29.37.0)** serve any function. Templates with **no ECU** act as subordinate CA certificates per [RFC 5280 #4.2.1.12](#), able to sign arbitrary new certificates.



ESC3 — Enrollment Agent Abuse

ESC3 chains two templates: first enroll for a Certificate Request Agent certificate, then use it to request certificates on behalf of privileged users via Schema V1 target templates, bypassing normal enrollment restrictions.

ESC15 (CVE-2024-49019 — “EKUwu”)

Discovered by TrustedSec (October 2024), [CVE-2024-49019](#) exploits Schema V1 templates where msPKI-Certificate-Application-Policy in the CSR overrides the template’s pKIExtendedKeyUsage. The WebServer template is the primary target.

Remediation: Patch all CAs and migrate V1 templates to V2+. See

[IX509ExtensionMSApplicationPolicies](#)

```
PS C:\Users\manor\Downloads\Playground> cat .\esc15_csr.cnf
# esc15_csr.cnf
[ req ]
default_bits          = 2048
distinguished_name    = req_distinguished_name
req_extensions        = v1_req
prompt                = no

[ req_distinguished_name ]
CN = TargetUser

[ v1_req ]
# Certificate Request Agent OID - what ESC15 injects
extendedKeyUsage = 1.3.6.1.4.1.311.20.2.1
```

```

PS C:\Users\manor\Downloads\Playground> openssl req -in escl5.csr -noout -text
Certificate Request:
  Data:
    Version: 1 (0x0)
    Subject: CN=TargetUser
    Subject Public Key Info:
      Public Key Algorithm: rsaEncryption
      Public-Key: (2048 bit)
      Modulus:
        00:d3:b4:b5:de:8b:45:4d:80:e5:c3:9b:ea:b5:c1:
        1b:9b:d7:b6:f4:1e:1b:7a:4f:90:04:14:3b:82:61:
        b8:e2:e9:75:1d:b7:c7:82:69:bb:2b:73:3b:a2:e4:
        31:b3:30:d7:b4:0a:a0:35:52:b2:5b:48:0d:3b:11:
        59:5b:2a:c8:81:bb:70:73:17:2b:ab:5e:7b:48:9e:
        92:a8:c2:a2:37:50:8f:de:89:0f:8f:01:1c:43:fb:
        f9:bf:9a:18:02:bf:bb:ae:b9:58:11:72:55:9a:30:
        92:35:cb:f0:71:b5:cf:7e:2a:f9:82:5c:98:1a:f3:
        97:e0:8b:40:39:8e:ad:b5:28:98:2b:c9:db:48:32:
        d9:7b:fb:78:f7:ef:47:4a:3b:b7:15:b4:82:d9:94:
        dc:58:78:94:2e:d3:ce:b5:31:53:91:f8:2a:14:8b:
        27:e9:42:b0:c5:7d:38:a5:78:09:d4:fc:b1:9e:55:
        08:bf:2a:9b:2e:03:42:ae:4e:10:17:ad:0c:17:29:
        af:57:1c:cf:e9:51:99:35:ba:48:a2:c2:7f:be:8e:
        bb:d1:45:92:7e:ab:0f:3b:d1:2e:e9:79:75:12:14:
        93:21:58:78:23:83:21:49:c1:72:fd:fe:1b:50:4e:
        09:e5:1b:3a:55:99:1b:b3:c8:4e:52:99:8b:79:5a:
        74:51
      Exponent: 65537 (0x10001)
    Attributes:
      Requested Extensions:
        X509v3 Extended Key Usage:
          1.3.6.1.4.1.311.20.2.1
  Signature Algorithm: sha256WithRSAEncryption
  Signature Value:
    ad:c2:88:5b:d4:47:4b:f3:4b:50:ef:9e:e9:f2:db:af:ed:1b:
    54:74:91:34:84:5c:ff:db:c0:ed:b5:ab:eb:1e:43:0f:41:ae:
    d2:eb:dd:47:e2:bd:9c:4c:08:bd:3b:a7:bb:f1:77:1d:f2:9a:
    df:2b:3a:f5:19:e5:15:9b:c0:7e:5c:23:58:37:19:25:db:a9:
    bc:53:12:f7:b9:ff:73:fa:7d:a4:5b:de:0d:24:2d:8f:ab:73:
    eb:ae:c3:bc:7d:b7:0a:e0:f4:be:44:b1:4a:e7:58:bc:48:08:
    53:9b:97:a2:b4:d1:4b:33:9d:70:40:e0:2a:2c:4a:70:e4:9b:
    7c:37:a2:aa:b4:1f:be:7e:f5:02:e2:04:e3:5f:98:e9:c3:4f:
    5d:ef:4b:20:9b:7b:d5:3a:8c:b4:7c:d5:47:21:7c:cc:5b:07:
    14:3b:3e:a1:75:59:43:93:d1:bf:ea:db:a9:fb:fb:5e:4a:29:
    9a:b2:4a:da:43:90:04:a8:98:d3:a7:ff:1c:fa:77:97:c7:43:
    ef:bb:8f:ca:5e:97:e7:8d:13:b4:3a:71:49:90:bf:bb:d9:3b:
    8f:b3:f7:45:94:5b:11:ee:f7:d3:e5:3b:1b:8e:bb:c7:c9:d2:
    30:bd:5b:3a:a4:1b:3d:3d:9c:07:88:37:4f:0b:77:ff:02:19:
    71:80:48:19

```

Access Control Failures

ESC4 — Template Object ACL Abuse

Low-privileged users with **Write**, **WriteDACL**, **WriteOwner**, or **GenericAll** on a template AD object can modify it into an ESC1-equivalent, request a privileged certificate, then restore settings—leaving minimal forensic trace.

Template Display Name	Schema Version	Version	Intended Purposes
 WeakKeyWebServer	2	100.3	Server Authentication
 Web Server	1	4.1	
 WebServerTemplate	2	100.3	Server Authentication
 Workstation Authentication	2	101.1	Client Authentication

Group or user names:

- Authenticated Users
- TestCCSUser Service (TestCCSUser@encon.local)**
- Domain Admins (ENCON\Domain Admins)
- Enterprise Admins (ENCON\Enterprise Admins)

Add... Remove

Permissions for TestCCSUser Service	Allow	Deny
Full Control	☒	☐
Read	☒	☐
Write	☒	☐
Enroll	☒	☐

For special permissions or advanced settings, click Advanced.

Advanced

OK Cancel Apply Help

ESC5 — PKI Object ACL Abuse

Extends ESC4 to all PKI AD objects: NTAuthCertificates, Enrollment Services, CA computer objects, and parent containers with inheritable ACEs. See [Microsoft's AD CS hardening guidance](#).

ESC7 — Vulnerable CA Access Control

Low-privileged users with **ManageCA** or **ManageCertificates** can enable the SubCA template, submit a request with arbitrary SAN (denied), then approve the failed request to obtain a SubCA certificate capable of signing anything.

enconCA03 Properties
?
X

Extensions
Storage
Certificate Managers

General
Policy Module
Exit Module

Enrollment Agents
Auditing
Recovery Agents
Security

Group or user names:

Authenticated Users
TestCCSUser Service (TestCCSUser@encon.local)
Domain Admins (ENCON\Domain Admins)
Enterprise Admins (ENCON\Enterprise Admins)
Administrators (CA03\Administrators)

Add...
Remove

Permissions for TestCCSUser Service	Allow	Deny
Read	☒	☐
Issue and Manage Certificates	☒	☐
Manage CA	☒	☐
Request Certificates	☒	☐

OK
Cancel
Apply
Help

CA Configuration Issues

ESC6 — EDITF_ATTRIBUTESUBJECTALTNAME2

If the CA has EDITF_ATTRIBUTESUBJECTALTNAME2 enabled, **any enrollee can specify an arbitrary SAN regardless of template settings.**

Disable on every CA:

```
certutil -setreg policy\EditFlags -EDITF_ATTRIBUTESUBJECTALTNAME2
```



```
Administrator: C:\Windows\system32\cmd.exe

C:\Users\Administrator.ENCON>certutil -setreg policy\EditFlags -EDITF_ATTRIBUTESUBJECTALTNAME2
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\enconCA03\PolicyModules\CertificateAuthority_
MicrosoftDefault.Policy\EditFlags:

Old Value:
EditFlags REG_DWORD = 15014e (1376590)
EDITF_REQUESTEXTENSIONLIST -- 2
EDITF_DISABLEEXTENSIONLIST -- 4
EDITF_ADDOLDKEYUSAGE -- 8
EDITF_BASICCONSTRAINTSCRITICAL -- 40 (64)
EDITF_ENABLEAKIKEYID -- 100 (256)
EDITF_ENABLEDEFAULTSMIME -- 10000 (65536)
EDITF_ATTRIBUTESUBJECTALTNAME2 -- 40000 (262144)
EDITF_ENABLECHASECLIENDC -- 100000 (1048576)

New Value:
EditFlags REG_DWORD = 11014e (1114446)
EDITF_REQUESTEXTENSIONLIST -- 2
EDITF_DISABLEEXTENSIONLIST -- 4
EDITF_ADDOLDKEYUSAGE -- 8
EDITF_BASICCONSTRAINTSCRITICAL -- 40 (64)
EDITF_ENABLEAKIKEYID -- 100 (256)
EDITF_ENABLEDEFAULTSMIME -- 10000 (65536)
EDITF_ENABLECHASECLIENDC -- 100000 (1048576)
CertUtil: -setreg command completed successfully.
The CertSvc service may need to be restarted for changes to take effect.
```

ESC12 — CA Private Key on External Device

Targets CAs with private keys on external [HSMs](#) (e.g., [YubiHSM](#)) where credentials are stored in plaintext in the registry. Emphasizes the need for [FIPS 140-2/140-3 Level 3](#) certified HSM deployments with proper credential management.

ESC16 — Global SID Extension Disabled

The SID security extension OID (1.3.6.1.4.1.311.25.2) is globally disabled in the CA's DisableExtensionList. Without it, the KDC cannot perform strong certificate mapping per [KB5014754](#).

```
Administrator: C:\Windows\system32\cmd.exe

C:\Users\Administrator.ENCON>certutil -getreg CA\DisableExtensionList
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\enconCA03\DisableExtensionList:

DisableExtensionList REG_MULTI_SZ =
0: 1.3.6.1.4.1.311.25.2
CertUtil: -getreg command completed successfully.

C:\Users\Administrator.ENCON>
```

The DisableExtensionList registry key exists for suppressing legacy or conflicting extensions. the SID extension (1.3.6.1.4.1.311.25.2) should **never** be in it on any production CA. It has no legitimate operational reason to be disabled.

Certificate Mapping Weaknesses

ESC9 — No Security Extension (Template-Level)

Templates with CT_FLAG_NO_SECURITY_EXTENSION (0x80000) prevent SID embedding, forcing weak UPN-based mapping. Exploitable when combined with the ability

to modify one's own UPN.

ESC10 — Weak Registry-Level Mapping

When StrongCertificateBindingEnforcement remains at 0 or 1. **As of September 2025, this key is permanently unsupported** per [KB5014754](#)—Full Enforcement is the only option.

ESC13 — Issuance Policy Group Link

Exploits msDS-OLDToGroupLink attributes linking issuance policy OIDs to privileged universal groups. See the detailed [ADCS ESC13 Abuse Technique](#).

ESC14 — Weak Explicit Certificate Mappings

Targets weak mappings in altSecurityIdentities (X509RFC822, X509IssuerSubject). Only strong mappings survive post-KB5014754 (X509IssuerSerialNumber, X509SKI, X509SHA1PublicKey).

Network Relay Attacks

ESC8 — NTLM Relay to HTTP Enrollment

Relays coerced NTLM authentication (via [CVE-2021-36942](#)) to AD CS web enrollment endpoints lacking HTTPS and EPA. The attacker obtains a DC certificate enabling DCSync. See [CA/B Forum Network Security Requirements](#) for web enrollment hardening principles.

ESC11 — NTLM Relay to RPC Enrollment

Targets the ICertPassage RPC interface. Remediation:

```
certutil -setreg CA\InterfaceFlags +IF_ENFORCEENCRYPTICERTREQUEST
```

What Microsoft, CISA, And NSA Wants You To Fix

KB5014754: Strong Certificate Mapping Is Permanent

Microsoft's response to [CVE-2022-26923](#) introduced the SID security extension (OID 1.3.6.1.4.1.311.25.2). Full enforcement timeline per [KB5014754](#):

- **May 2022:** Compatibility mode—SID extension added, weak mapping still accepted
- **April 2023:** Disabled mode removed
- **February 2025:** Full Enforcement activated by default
- **September 2025:** StrongCertificateBindingEnforcement key permanently unsupported

Impact: Only X509IssuerSerialNumber, X509SKI, and X509SHA1PublicKey mappings survive. For guidance on updating certificate mappings, see [Encryption Consulting's Microsoft's Strong Certificate Mapping Enforcement blog](#).

Windows Server 2025 AD CS Enhancements

- **CRL Partitioning:** Splits monolithic CLRs into serial-number-range partitions for large deployments (see [powerful enhancements to ADCS in 2025](#))
- **16KB+ Extension Limit:** Enables PQC-ready metadata (see [Encryption Consulting's Post-Quantum Cryptography guide](#))
- **Enhanced Audit Events:** 4886–4889 now include SAN values, template name, client OS, CSP, and auth type ([Microsoft audit documentation](#))
- **Security Defaults:** LDAP encryption mandatory, Credential Guard enabled, NTLM deprecation, RC4 deprecated in Kerberos

Government and Industry Advisories

- [CISA/NSA AA23-278A \(October 2023\)](#): Names AD CS misconfigurations as a top-ten cybersecurity finding. Mandates Tier 0 CA classification.
- [Five Eyes Joint Advisory \(September 2024\)](#): Co-authored by ASD, CISA, NSA, CCCS, NCSC-NZ, NCSC-UK. Highlights ESC1 and ESC8 by name.
- [MITRE ATT&CK T1649](#): Detection/mitigation framework for certificate theft and forgery (M1047, M1042, M1041).
- [CISA Known Exploited Vulnerabilities Catalog](#): [CVE-2022-26923](#) and [CVE-2024-49019](#) listed with mandatory remediation deadlines.
- [NIST SP 800-57 \(Key Management\)](#) and [SP 800-152 \(Federal CKMS Profile\)](#): Cryptographic governance framework. SP 800-57 Rev. 6 (draft) adds quantum-resistant algorithm guidance.
- [NIST SP 800-53 Rev. 5 \(Security Controls\)](#): SC-12 (Cryptographic Key Establishment), SC-17 (PKI Certificates), IA-5 (Authenticator Management) directly apply to AD CS governance.
- [NIST SP 800-207 \(Zero Trust Architecture\)](#): Certificate-based identity is foundational to zero trust. See also [Encryption Consulting's Zero Trust guide](#).

The 15-Point Template Hardening Checklist

Implement these controls immediately. Each maps to specific ESC vectors and aligns with [CISA AA23-278A](#), [NIST SP 800-53 SC-12/SC-17](#), and [Microsoft's AD CS hardening guidance](#):

1. **Unpublish all unused default templates.** Most environments use 5–8 but leave 32+ published. [Reduces: ESC1–ESC3, ESC15]

- To see what's currently published:

```
certutil -catemplates
```

- Remove templates from the CA's published list:

```
certutil -setcatemplates -<TemplateName1>,<TemplateName2>
```

2. **Disable CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT everywhere not operationally required.** Enable manager approval as compensating control. [Reduces: ESC1]

- This is a per-template flag stored in AD (msPKI-Certificate-Name-Flag). To inspect the current value:

```
certutil -dstemplate <TemplateName>
```

- Look for msPKI-Certificate-Name-Flag. If bit 1 is set, clear it via ADSI Edit or:

```
certutil -dstemplate <TemplateName> msPKI-Certificate-Name-Flag -1
```

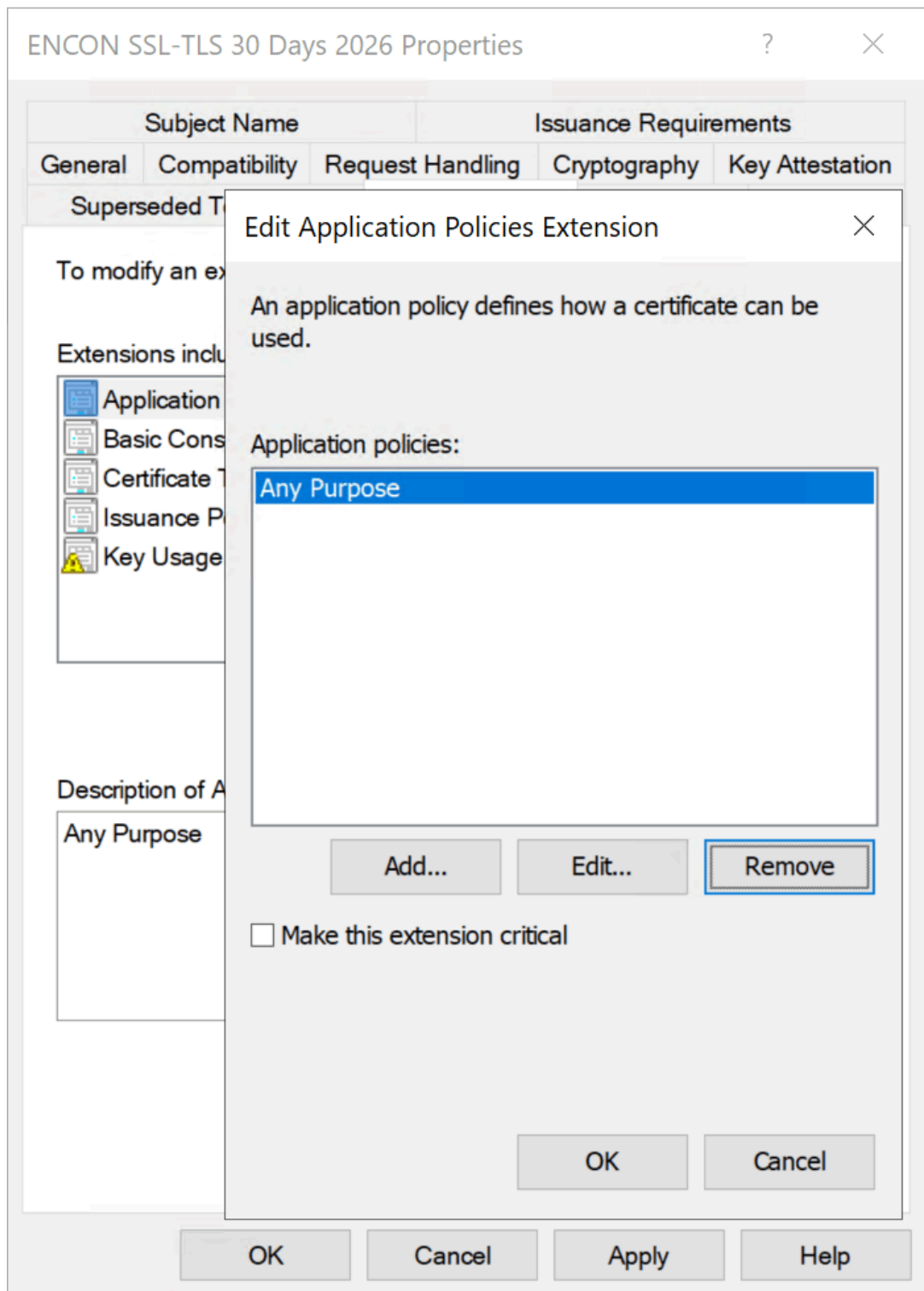
3. **Remove AnyPurpose ECU; eliminate templates with no ECU** unless serving as subordinate CAs. Per [RFC 5280 #4.2.1.12](#), missing ECU = SubCA behavior.

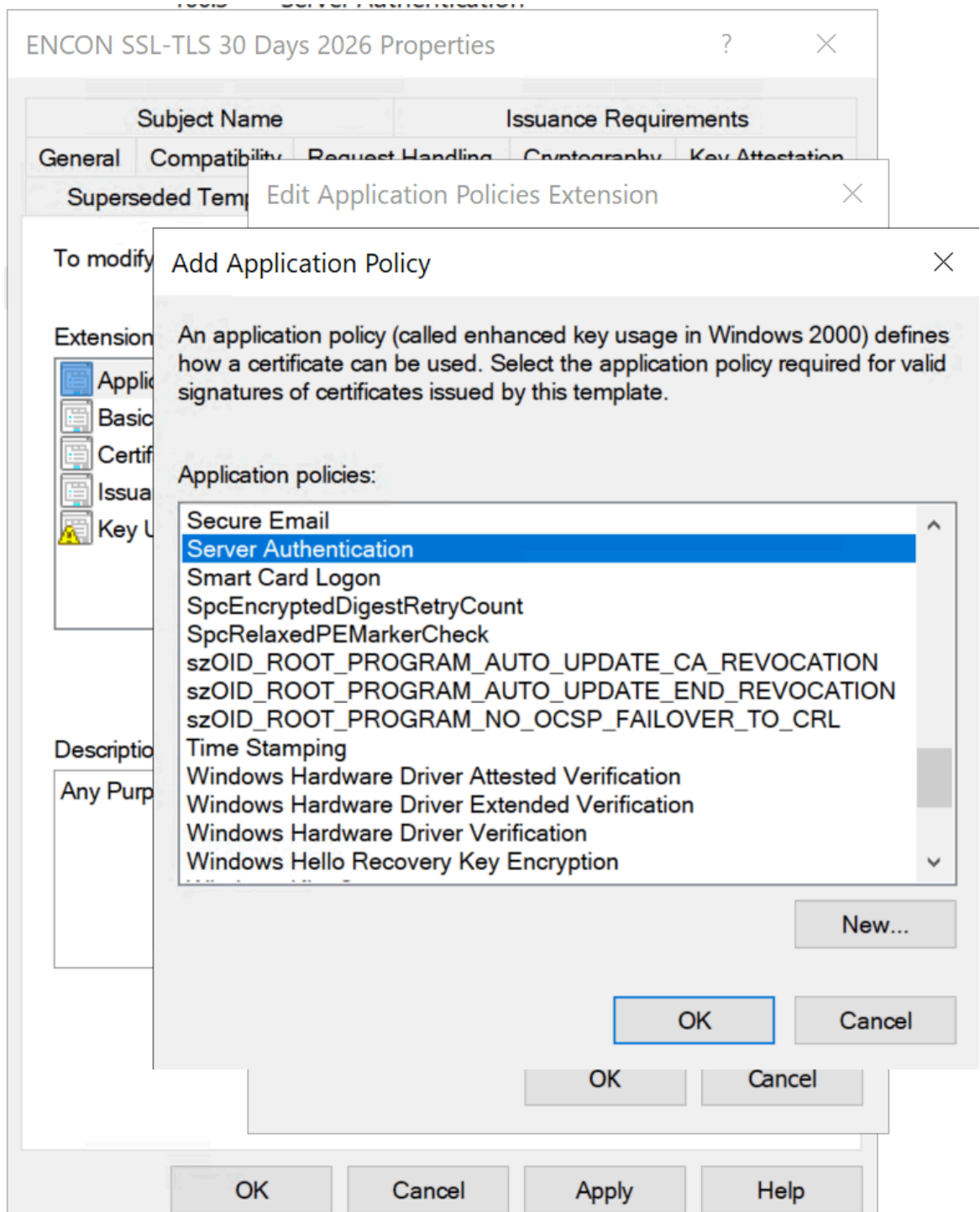
[Reduces: ESC2]

- ECU is **msPKI-Certificate-Application-Policy** and **pKIExtendedKeyUsage** on the template AD object. Inspect with:

```
certutil -dtemplate <TemplateName>
```

- Remediation: set specific EKU OIDs and remove **OID 2.5.29.37.0** (anyExtendedKeyUsage).





Subject Name		Issuance Requirements		
General	Compatibility	Request Handling	Cryptography	Key Attestation
Superseded Templates		Extensions		Security
		Server		

To modify an extension, select it, and then click Edit.

Extensions included in this template:

 Application Policies
 Basic Constraints
 Certificate Template Information
 Issuance Policies
 Key Usage

Edit...

Description of Application Policies:

Server Authentication

OK Cancel Apply Help

4. **Restrict Enroll/Autoenroll to specific named security groups.** Never Authenticated Users / Domain Users / Domain Computers on sensitive templates. [Reduces: ESC1–ESC3, ESC15]

ENCON SSL-TLS 30 Days 2026 Properties

Subject Name Issuance Requirements

General Compatibility Request Handling Cryptography Key Attestation

Superseded Templates Extensions Security Server

Group or user names:

- Authenticated Users
- CertSecure (CertSecure@encon.local)**
- Administrator
- Domain Admins (ENCON\Domain Admins)
- Enterprise Admins (ENCON\Enterprise Admins)

Add... Remove

Permissions for CertSecure

	Allow	Deny
Full Control	☐	☐
Read	☒	☐
Write	☐	☐
Enroll	☒	☐
Autoenroll	☒	☐

For special permissions or advanced settings, click Advanced.

Advanced

OK Cancel Apply Help

5. Enable manager approval + authorized signatures on WebServer, CodeSigning, SmartCardLogon, EnrollmentAgent. [Reduces: ESC1, ESC3]

The screenshot shows the 'ENCON Code Signing 2026 Properties' dialog box with the 'Issuance Requirements' tab selected. The 'Subject Name' tab is also visible. The 'Require the following for enrollment:' section has two checked options: 'CA certificate manager approval' and 'This number of authorized signatures:' with a value of 1. Below this, it states 'If you require more than one signature, autoenrollment is not allowed.' The 'Policy type required in signature:' dropdown is set to 'Application policy', and the 'Application policy:' dropdown is set to 'Code Signing'. There is an empty box for 'Issuance policies:' with 'Add...' and 'Remove' buttons. The 'Require the following for reenrollment:' section has 'Same criteria as for enrollment' selected. A note at the bottom states '* Control is disabled due to compatibility settings.' The 'Cancel' button is highlighted.

6. **Set minimum key size to 2048-bit RSA (4096-bit for CA keys) or ECDSA P-384.**
Disable SHA-1 per [NIST SP 800-57](#) deprecation schedule. [Aligns: NIST, [CA/B Forum BR](#)]

- Minimum key size is msPKI-Minimal-Key-Size on the template. Inspect with:

```
certutil -dstemplate <TemplateName>
```

- To set SHA-256 minimum on the CA itself:

```
certutil -setreg ca\csp\CNGHashAlgorithm SHA256
```

```
net stop certsvc & net start certsvc
```

- Verify:

```
certutil -getreg ca\csp\CNGHashAlgorithm
```

- Confirm current signing algorithm:

```
certutil -getreg ca\csp\CNGPublicKeyAlgorithm
```

7. Disable EDITF_ATTRIBUTESUBJECTALTNAME2 on every CA. [Reduces: ESC6]

```
certutil -setreg policy\EditFlags -EDITF_ATTRIBUTESUBJECTALTNAME2  
net stop certsvc & net start certsvc
```

8. Enforce RPC encryption. [Reduces: ESC11]

```
certutil -setreg CA\InterfaceFlags +IF_ENFORCEENCRYPTICERTREQUEST  
net stop certsvc & net start certsvc
```

9. Harden or remove HTTP web enrollment. Enforce HTTPS + EPA. Disable NTLM. Align with [CAB Forum Network Security Requirements](#). [Reduces: ESC8]

- To disable remote RPC-based requests:

```
certutil -setreg CA\InterfaceFlags +IF_NOREMOTEICERTREQUEST
```

- That disables remote RPC-based requests; for HTTP/CES specifically, uninstall the web enrollment role or reconfigure IIS.

10. Lock template and CA DACLs to Tier 0 accounts only. Audit all PKI AD objects. [Reduces: ESC4, ESC5, ESC7]

View the CA's security descriptor:

```
certutil -getreg CA\Security
```

11. Remove CT_FLAG_NO_SECURITY_EXTENSION from all templates. Ensure SID extension per KB5014754. [Reduces: ESC9]

- This is **msPKI-Enrollment-Flag** bit **0x80000** on the template. Inspect:

```
certutil -dtemplate <TemplateName>
```

- To confirm SID extension is being stamped (KB5014754), check the CA's registry:

```
certutil -getreg policy\EditFlags
```

- Ensure **EDITF_ATTRIBUTESUBJECTALTNAME2** is already off (see checklist 7) and the OS is patched for [KB5014754](#).

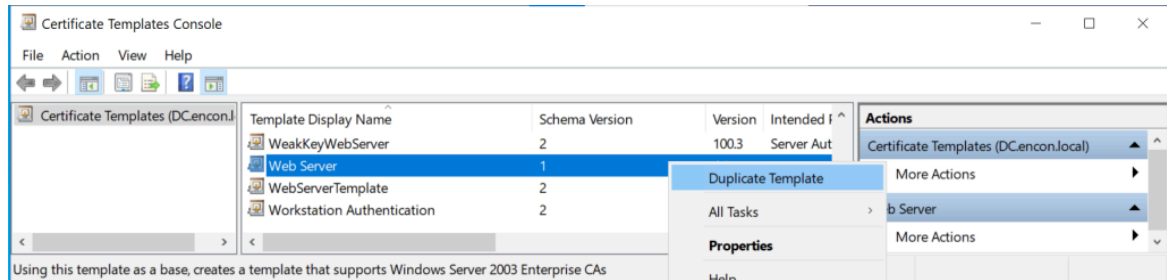
12. Patch for ESC15 ([CVE-2024-49019](#)). Migrate Schema V1 → V2+ by duplicating.

[Reduces: ESC15]

- To check a template's schema version (look for msPKI-Template-Schema-Version):

```
certutil -dtemplate <TemplateName>
```

- V1 templates must be duplicated to V2+ through `certtmpl.msc`.



13. Audit every msDS-OIDToGroupLink and altSecurityIdentities. Remove unauthorized links and weak mappings. [Reduces: ESC13, ESC14]

14. **Disable private key export** on all templates not requiring portability. [Reduces: certificate theft]

- This is msPKI-Private-Key-Flag on the template — clear bit 0x10 (CT_FLAG_EXPORTABLE_KEY). Inspect:

certutil -dtemplate <TemplateName>

- Via GUI: open certtmpl.msc → right-click template → Properties → Request Handling tab → uncheck “Allow private key to be exported” → OK.

The screenshot shows the 'ENCON-1-Day-TLS Properties' dialog box with the 'Request Handling' tab selected. The 'Purpose' dropdown is set to 'Signature and encryption'. Below it are three unchecked checkboxes: 'Delete revoked or expired certificates (do not archive)', 'Include symmetric algorithms allowed by the subject', and 'Archive subject's encryption private key'. Further down is an unchecked checkbox for 'Authorize additional service accounts to access the private key (*)' with a 'Key Permissions...' button next to it. The checkbox 'Allow private key to be exported' is highlighted with a red rectangle and is currently unchecked. Below it are two more unchecked checkboxes: 'Renew with the same key (*)' and 'For automatic renewal of smart card certificates, use the existing key if a new key cannot be created (*)'. At the bottom, there is a section titled 'Do the following when the subject is enrolled and when the private key associated with this certificate is used:' with three radio button options: 'Enroll subject without requiring any user input' (selected), 'Prompt the user during enrollment', and 'Prompt the user during enrollment and require user input when the private key is used'. A note at the bottom states '* Control is disabled due to [compatibility settings](#).' The dialog has 'OK', 'Cancel', 'Apply', and 'Help' buttons at the bottom.

15. **Enable role separation; never co-locate AD CS on a DC.** Protect CA keys with [FIPS 140-3 Level 3 HSMs](#) (see [How Encryption Consulting can help](#)).

```
certutil -setreg ca\RoleSeparationEnabled 1
```

```
net stop certsvc & net start certsvc
```

- For HSM-backed CA keys, configure during CA installation or key migration via the HSM vendor's CSP/KSP. To verify the current CSP:

```
certutil -getreg ca\csp
```

Enterprise PKI Services

Get complete end-to-end consultation support for all your PKI requirements!

[Learn More](#)

Certificate Lifecycle: Governance from Enrollment to Revocation

Template hardening alone is insufficient without [certificate lifecycle management](#) governance across the entire certificate lifespan. The lifecycle framework aligns with [NIST SP 800-57 #8 \(Key Management Lifecycle\)](#) and [RFC 3647 \(Certificate Policy / CPS Framework\)](#):

Enrollment Controls

Define authorization workflows per [NIST SP 800-53 IA-5 \(Authenticator Management\)](#). Use Group Policy autoenrollment for standard certificates; require manual request and approval for high-value templates. For modern enrollment protocols, consider [EST \(RFC 7030\)](#), [CMP \(RFC 4210\)](#), or [ACME \(RFC 8555\)](#).

Issuance Validation

The CA should validate requesters, subject information, and SANs. Open-source policy modules like [TameMyCerts](#) enforce rules at issuance time. For enterprise-grade lifecycle automation, see [CertSecure Manager](#).

Revocation and Status Checking

Maintain [CRL distribution points](#) and [OCSP responders \(RFC 6960\)](#) for real-time validity checking. Monitor revocation failures (Event IDs 4870–4873). For [OCSP Stapling and Certificate Lifespans](#), see Encryption Consulting's guide.

Validity Periods and Renewal

Per [CA/B Forum Baseline Requirements](#), publicly-trusted TLS certificates max at 398 days. Internal recommendations: 1 year user, 2 years computer, 5 years issuing CA, 10–20 years

offline root. Align with [NIST SP 800-57 Part 1](#) cryptoperiod guidance.

Key Archival and Recovery

Enable key archival on encryption templates for business continuity. Designate Key Recovery Agents with strict controls per [NIST SP 800-152 \(Federal CKMS Profile\)](#).

Auditing Strategy: The Event IDs That Matter

Auditing is the most neglected aspect of AD CS operations. Enable full CA auditing per [Microsoft's Audit Certification Services documentation](#):

1. **Set CA audit filter:** certutil -setreg ca\auditfilter 127 (all seven categories)
2. **Enable Group Policy subcategory:** Advanced Audit Policy → Object Access → Audit Certification Services → Success and Failure

Critical Event IDs

Event ID	Description	What to Watch For
4886	Certificate request received	Unusual requester/template combos; unexpected source IPs
4887	Certificate approved and issued	SAN/requester mismatch; privileged identities in SAN field
4888	Certificate request denied	Repeated denials may indicate ESC7 deny-then-approve attacks
4890	CA manager settings changed	Unauthorized CA config changes (ESC6, ESC7)
4899/4900	Template modified / security updated	Template property or ACL changes (ESC4, ESC5 detection)
4768	Kerberos TGT request	PreAuthType=16 = certificate-based auth (RFC 4556 PKINIT); correlate with 4887

Forward all CA events to your SIEM. Correlate with [MITRE ATT&CK T1649 detection guidance](#) and [Microsoft Defender for Identity AD CS alerts](#).

Tooling That Exposes Your AD CS Blind Spots

Offensive (Authorized Testing)

- [Certify 2.0 \(SpecterOps\)](#): C# standard supporting ESC1–ESC16. find /vulnerable enumerates all exploitable misconfigurations.
- [Certipy \(Oliver Lyak\)](#): Python-based, Linux-friendly. BloodHound-compatible JSON output, NTLM relay for ESC8.

Defensive

- [Locksmith 2 \(Trimarc Security\)](#): Best-in-class PowerShell auditing for ESC1–ESC16. **Generates remediation scripts** per finding.
- [PSPKIAudit \(SpecterOps\)](#): PowerShell toolkit for ESC1–ESC8, with Get-CertRequest for incident response.
- [BloodHound 5.4+](#): Full AD CS node/edge integration (ADCSESC1, ADCSESC3, ADCSESC6a/b, ADCSESC9a/b, ADCSESC10a/b, ADCSESC13, GoldenCert).
- [Microsoft Defender for Identity](#): AD CS sensor with real-time posture assessments for ESC1–ESC8, ESC11, ESC15.
- [TameMyCerts](#): Open-source CA policy module blocking malformed requests at issuance time. Validates subject names, restricts SANs, enforces key sizes.
- [CertSecure Manager \(Encryption Consulting\)](#): Enterprise [certificate lifecycle management](#) platform providing automated discovery, enrollment, renewal, and revocation across multi-CA environments.

The Operational Reality: Why On-Premises AD CS Is Losing Ground

AD CS was built for Windows-centric, on-premises environments. For a detailed analysis of the limitations, read our blog on [Navigating Risks in Active Directory Certificate Services](#).

Non-Windows Devices and BYOD

Auto-enrollment works exclusively via Group Policy. macOS, Linux, iOS, Android, and ChromeOS lack native support. NDES/SCEP ([RFC 5272 / CMC](#)) is the typical workaround, but introduces security concerns. Modern alternatives include [EST \(RFC 7030\)](#) and [ACME \(RFC 8555\)](#)—neither natively supported by AD CS.

Remote and Hybrid Workforce

Certificate enrollment via RPC/DCOM requires DC and CA connectivity. Remote workers face renewal failures when VPN itself requires a valid certificate. [Zero trust architectures \(NIST SP 800-207\)](#) demand certificate-based identity regardless of network location.

Cost and Expertise Burden

Total cost of Ownership includes CA hardware, HSMs ([FIPS 140-3](#) certified), Windows Server licensing, offline root facilities, specialized PKI staff, CRL/AIA infrastructure, and patch testing. As of 2026, 62% of organizations report lacking sufficient PKI expertise.

The Pragmatic Hybrid Approach

The optimal strategy: hardened AD CS for domain-integrated workloads paired with a [modern managed PKI platform](#) for BYOD, multi-OS, cloud workloads, IoT/OT, and remote workforce. See [Encryption Consulting's PKI Design and Implementation](#) for hybrid architectures.

Secure Your PKI: How Encryption Consulting Can Help

AD CS template security requires continuous governance, monitoring, and expertise. [Encryption Consulting](#) delivers specialized PKI knowledge across assessment, implementation, and managed services:

PKI Assessment Services

Our comprehensive [PKI Health Assessment](#) examines every aspect of your AD CS deployment through the ESC1–ESC16 taxonomy, [CISA/NSA mandates](#), [NIST SP 800-53 controls](#), and Microsoft best practices:

- **Certificate Template Audit:** Systematic review of AD CS Certificate Template configurations and usage posture for exploitable misconfigurations.
- **CA Infrastructure Review:** Hierarchy design, [HSM configuration](#) ([FIPS 140-3](#) compliance), role separation, audit logging, CRL/AIA health.
- **Attack Path Analysis:** Mapping every exploitable path per the [Certified Pre-Owned](#) framework and [MITRE ATT&CK T1649](#).
- **Governance Gap Analysis:** Assessment against [NIST SP 800-57](#), [SP 800-152](#), [RFC 3647 \(CP/CPS\)](#), and [CA/B Forum Baseline Requirements](#).
- **Remediation Roadmap:** Prioritized, actionable recommendations with implementation guidance and rollback plans.

PKI as a Service (PKIaaS)

Reduce operational complexity while strengthening security with our [Managed PKI](#):

- **Cloud-Managed CA:** Fully managed with [HSM-backed](#) key protection, built-in redundancy, SLA-backed availability.
- **Multi-Protocol Enrollment:** Native [SCEP \(RFC 5272\)](#), [EST \(RFC 7030\)](#), [ACME \(RFC 8555\)](#), [CMP \(RFC 4210\)](#) support for every device/OS/architecture.

- **Automated Lifecycle Management:** Via [CertSecure Manager](#)—discovery, enrollment, renewal, and revocation across your entire enterprise.
- **Cross-Platform Support:** Windows, macOS, Linux, iOS, Android, ChromeOS, IoT, cloud workloads—single management plane.
- **Compliance-Ready Reporting:** Aligned with [NIST SP 800-53](#), [SP 800-171](#), SOC 2, PCI DSS, and HIPAA.

Your domain's integrity depends on certificate infrastructure security. [Contact Encryption Consulting today](#) to schedule a PKI Health Assessment.

References and Standards Index

This article references the following public standards, advisories, and tools:

IETF RFCs

- [RFC 5280](#) – Internet X.509 PKI Certificate and CRL Profile
- [RFC 6960](#) – Online Certificate Status Protocol (OCSP)
- [RFC 4556](#) – Public Key Cryptography for Initial Authentication in Kerberos (PKINIT)
- [RFC 3647](#) – Internet X.509 PKI Certificate Policy and Certification Practices Framework
- [RFC 8446](#) – Transport Layer Security (TLS) Protocol Version 1.3
- [RFC 6125](#) – Representation and Verification of Application Service Identity
- [RFC 7030](#) – Enrollment over Secure Transport (EST)
- [RFC 8555](#) – Automatic Certificate Management Environment (ACME)
- [RFC 4210](#) – Certificate Management Protocol (CMP)
- [RFC 5272](#) – Certificate Management over CMS (CMC)

NIST Publications

- [SP 800-57 Part 1 Rev. 5](#) – Recommendation for Key Management
- [SP 800-152](#) – A Profile for U.S. Federal Cryptographic Key Management Systems
- [SP 800-53 Rev. 5](#) – Security and Privacy Controls for Information Systems
- [SP 800-207](#) – Zero Trust Architecture
- [SP 800-63-4 \(Draft\)](#) – Digital Identity Guidelines
- [FIPS 140-2](#) / [FIPS 140-3](#) – Security Requirements for Cryptographic Modules

CVEs

- [CVE-2022-26923](#) – Certifried (AD DS Elevation of Privilege)
- [CVE-2024-49019](#) – EKUwu / ESC15 (AD CS ECU Override)
- [CVE-2021-36942](#) – PetitPotam (NTLM Relay)

Government Advisories

- [CISA/NSA AA23-278A](#) – NSA and CISA Top Ten Cybersecurity Misconfigurations
- [Five Eyes Joint Advisory \(Sept 2024\)](#) – Detecting and Mitigating Active Directory Compromises
- [CISA Known Exploited Vulnerabilities Catalog](#)
- [MITRE ATT&CK T1649](#) – Steal or Forge Authentication Certificates

CA/Browser Forum

- [Baseline Requirements for TLS Server Certificates](#)
- [Network and Certificate System Security Requirements](#)

Microsoft Documentation

- [KB5014754 – Certificate-based Authentication Changes](#)
- [Secure Configuration and Hardening of AD CS](#)
- [Audit Certification Services](#)
- [Defender for Identity AD CS Posture Assessments](#)

Security Research and Tools

- [SpecterOps: Certified Pre-Owned \(PDF\)](#)
- [SpecterOps: BloodHound AD CS Attack Paths](#)
- [SpecterOps: ESC13 Abuse Technique](#)
- [Certify \(GhostPack\)](#) | [PSPKIAudit](#)
- [Certipy](#) | [Locksmith 2](#) | [TameMyCerts](#)

Encryption Consulting Resources

- [ADCS 2025 Enhancements Blog](#)
- [Microsoft's Strong Certificate Mapping Enforcement](#)
- [CertSecure Manager](#) – Certificate Lifecycle Management Platform
- [PKI Services](#) | [Managed PKI](#) | [Consulting Services](#)
- [PKI Health Check](#) | [Security Assessment](#) | [CBOM Services](#)
- Education Center: [PKI](#) | [HSM](#) | [CLM](#) | [OCSP](#) | [CRL](#) | [Code Signing](#) | [Key Management](#) | [Zero Trust](#) | [PQC](#)

Conclusion

Certificate template misconfigurations remain the single most underestimated attack surface in enterprise Active Directory environments. The ESC taxonomy continues to grow, red-team tooling automates exploitation faster than most blue teams can audit, and regulatory enforcement from Microsoft, CISA, and Five Eyes partners has eliminated the grace period.

The defenses outlined in this playbook are not aspirational; they are the operational baseline. Organizations that treat their CA infrastructure with the same rigor as their domain controllers will close the gap. Those that delay will find attackers have already mapped what they left exposed.

If your team needs a starting point, Encryption Consulting's [PKI Health Check](#) can identify what this playbook describes — before an adversary does.

- [Certificate Template Anatomy: The Eight Significant Properties That Define Your Risk Posture](#)
 - [Template Property Tabs and Their Security Implications](#)
 - [Understanding Subject Types and Key Usage Categories](#)
 - [Default Templates: Risk Profiles You Must Know](#)
- [Most Common Enterprise Use Cases](#)
- [ESC1 Through ESC16: The Complete Attack Taxonomy](#)
 - [Template Misconfiguration Attacks](#)
 - [Access Control Failures](#)
 - [CA Configuration Issues](#)
 - [Certificate Mapping Weaknesses](#)
 - [Network Relay Attacks](#)
- [What Microsoft, CISA, And NSA Wants You To Fix](#)
- [The 15-Point Template Hardening Checklist](#)
- [Certificate Lifecycle: Governance from Enrollment to Revocation](#)
- [Auditing Strategy: The Event IDs That Matter](#)
- [Tooling That Exposes Your AD CS Blind Spots](#)
- [The Operational Reality: Why On-Premises AD CS Is Losing Ground](#)
- [Secure Your PKI: How Encryption Consulting Can Help](#)
 - [PKI Assessment Services](#)
 - [PKI as a Service \(PKIaaS\)](#)
- [References and Standards Index](#)
- [Conclusion](#)